

CLOUD SECURITY ASSESSMENT - PROWLER

SUMMARY

This project focused on assessing and improving the security posture of an AWS Free Tier cloud environment using Prowler, an open-source cloud security posture management tool.

The assessment targeted key AWS services including, AWS Identity and Access Management (IAM), Elastic Compute Cloud (EC2), Simple Storage Service (S3), AWS CloudTrail, AWS Lambda.

An initial security assessment identified multiple critical, high, medium, and low severity findings. Remediation activities were performed to address the most significant security risks, followed by a reassessment to validate the effectiveness of the implemented controls.

The project demonstrated the complete cloud security assessment lifecycle, including environment setup, vulnerability identification, remediation, risk acceptance, and reassessment.

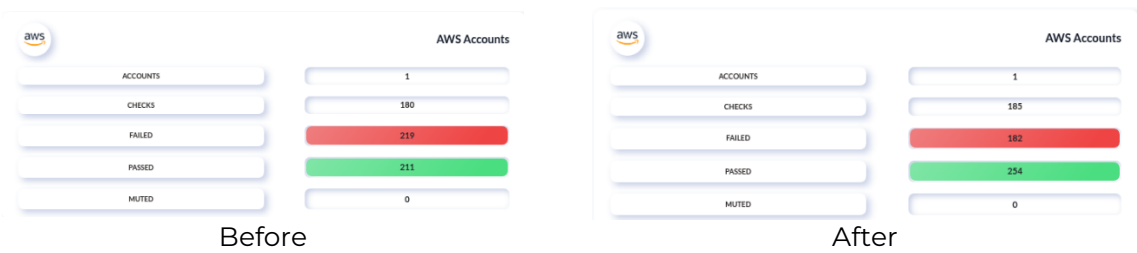
Assessment Results Summary

Severity	Initial Scan	Reassessment
Critical	4	2
High	18	9
Medium	110	91
Low	87	76

Security Posture Improvement

Metric	Initial Assessment	Reassessment
Total Checks	180	185
Passed Checks	211	254
Failed Checks	219	182

A total reduction of 37 failed security checks was achieved, while successful security controls increased by 43 checks.



CLOUD SECURITY ASSESSMENT - PROWLER

OVERVIEW

Assess the security posture of an AWS cloud environment using Prowler, identify misconfigurations, remediate findings, and validate improvements through reassessment.

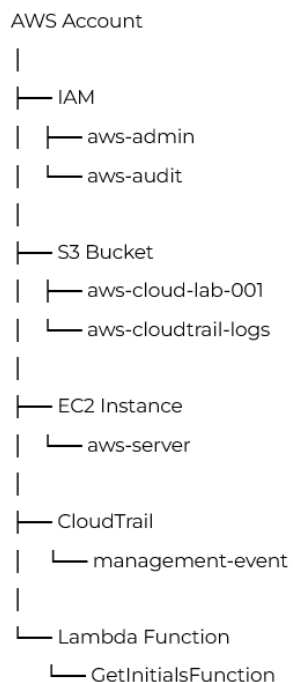
The project followed a structured assessment methodology:

- Environment Setup
- Security Assessment
- Findings Analysis
- Remediation
- Reassessment
- Risk Acceptance Documentation

Tools Used

- AWS Free Tier
- Kali Linux
- Docker
- Prowler
- AWS IAM
- Amazon EC2
- Amazon S3
- AWS CloudTrail
- AWS Lambda

Lab Overview



CLOUD SECURITY ASSESSMENT - PROWLER

Assessment Scope

In-Scope services

- Identity and Access Management (IAM)
- Amazon Elastic Compute Cloud (EC2)
- Amazon Simple Storage Service (S3)
- AWS CloudTrail
- AWS Lambda

These core services were intentionally deployed within an AWS Free Tier environment and served as the primary focus of this security assessment and subsequent remediation efforts.

Out-of-Scope Services

- **AWS Native Infrastructure:** AWS Organizations, AWS IAM Access Analyzer, and Amazon CloudWatch.
- **Advanced/AI Services:** Amazon Bedrock and Amazon SageMaker.
- **Governance Tools:** AWS Config and any other AWS services not explicitly deployed for this project.

While the Prowler security scanner automatically flagged findings across these broader cloud infrastructure components, they fell outside the defined boundaries of this project and were excluded from active remediation.

Remediation Constraints

Remediation was strictly limited to the In-Scope services and actions that could be executed without introducing financial overhead. Several Prowler recommendations were deferred, and risk was accepted because they violated Free Tier constraints or project boundaries by requiring paid features, including:

- **Advanced Security Services:** Deploying AWS Network Firewall.
- **Storage Encryption:** Implementing Customer Managed Keys (CMKs) via AWS Key Management Service (KMS) for S3 bucket encryption.
- **Messaging & Alerting:** Setting up Amazon SNS and Amazon SQS infrastructure for automated alerting.
- **Physical Hardware:** Enforcing physical hardware MFA tokens.

CLOUD SECURITY ASSESSMENT - PROWLER

ASSESSMENT METHODOLOGY

Phase 1 – Environment Creation

AWS resources were deployed to create a realistic cloud environment for assessment.

Phase 2 – Security Assessment

Prowler was executed against the AWS account to evaluate security controls, configurations, encryption settings, logging configurations, and identity management practices.

Phase 3 – Findings Analysis

Assessment results were reviewed and categorized according to severity:

- Critical
- High
- Medium
- Low

Phase 4 – Remediation

Security findings were analyzed and remediated where feasible within AWS Free Tier limitations.

Phase 5 – Reassessment

A second Prowler assessment was performed to verify remediation effectiveness and measure security improvements.

CLOUD SECURITY ASSESSMENT - PROWLER

ENVIRONMENT SETUP

An AWS environment was created to simulate a small cloud infrastructure.

Resources Configure

- AWS IAM
- Amazon S3
- AWS EC2 Instance
- AWS Security Groups
- AWS Cloudtrail
- AWS Lambda

Assessment Account Permissions

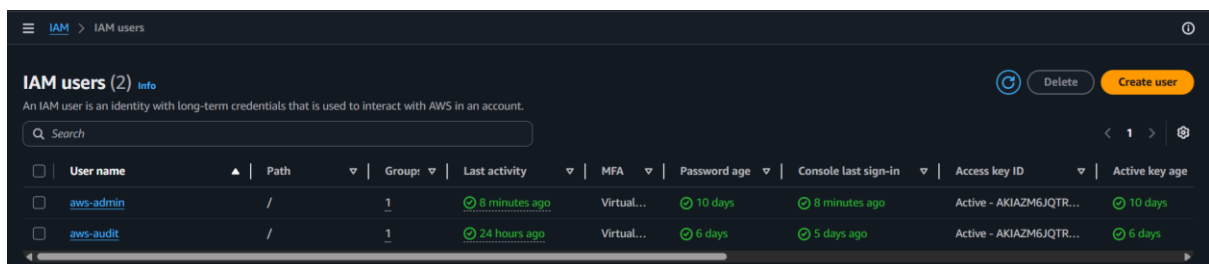
- ViewOnlyAccess
- SecurityAudit

This ensured a read-only assessment approach while maintaining security best practices.

AWS Services Overview

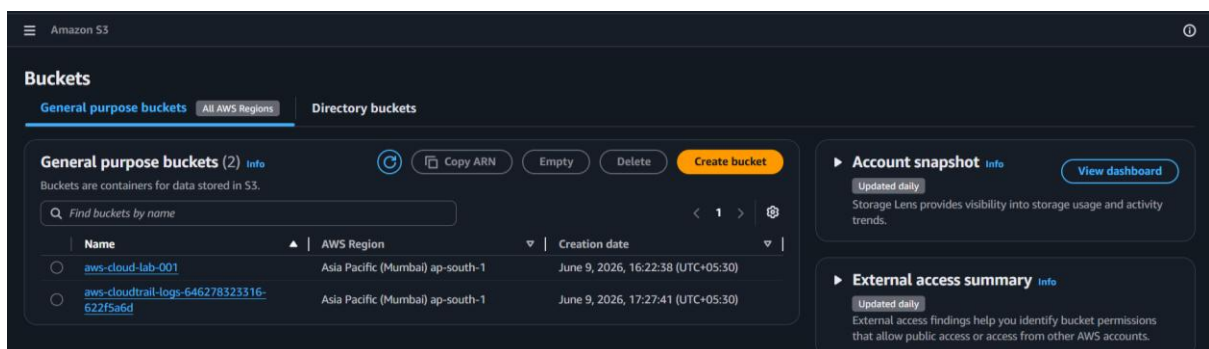
AWS IAM

AWS IAM is the security backbone of your AWS environment. It centrally controls **who** can authenticate (sign in) and **what** permissions they have to interact with your cloud resources.



Amazon S3

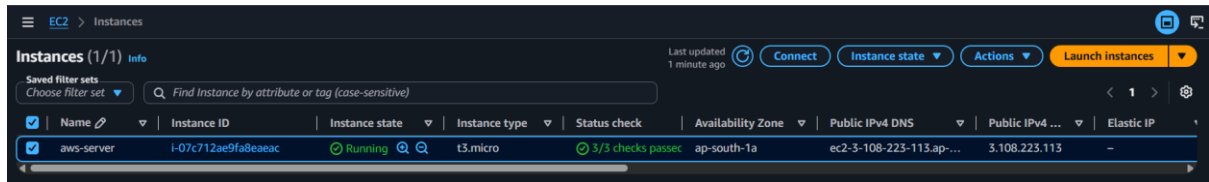
Amazon S3 is a highly scalable, **object-based storage service** designed to store and retrieve any amount of data from anywhere on the web.



CLOUD SECURITY ASSESSMENT - PROWLER

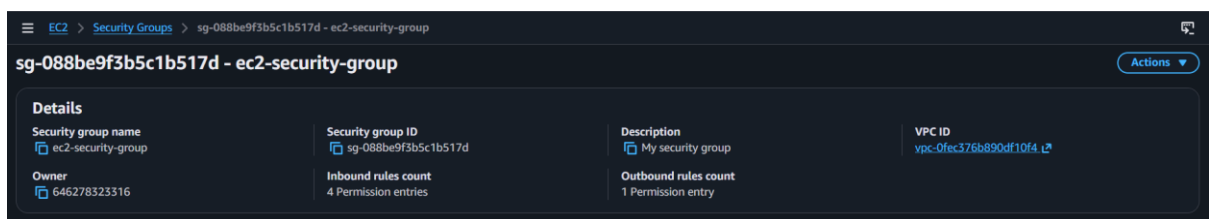
Amazon EC2

Amazon EC2 provides **resizable virtual servers** (known as instances) in the cloud. It eliminates the need to buy physical hardware, allowing you to deploy applications quickly.



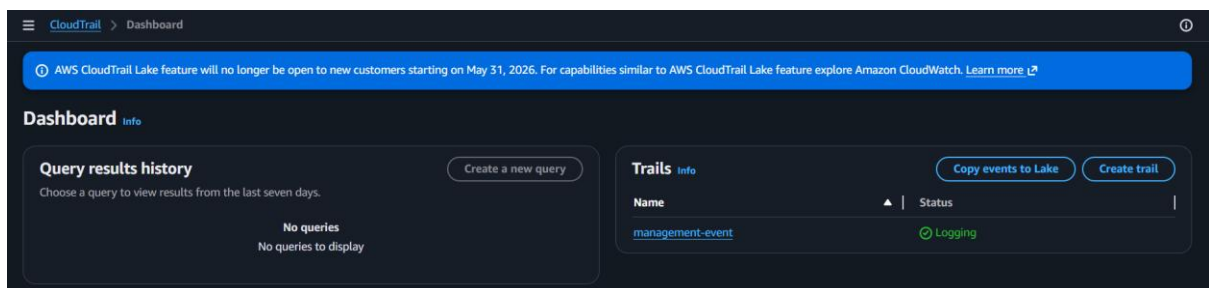
Security Groups

Security Groups act as a **built-in virtual firewall** for your EC2 instances to control inbound and outbound network traffic.



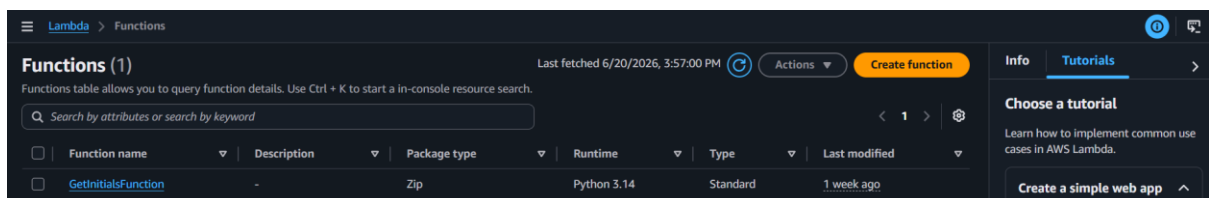
AWS Cloudtrail

AWS CloudTrail is a governance, compliance, and risk auditing service that **records actions taken by a user, role, or an AWS service**.



AWS Lambda

AWS Lambda is a **serverless compute service** that lets you run code without provisioning or managing underlying servers.



CLOUD SECURITY ASSESSMENT - PROWLER

AWS-CLI Configuration

AWS CLI is a unified open-source tool that allows you to interact with and manage your AWS services using commands in your terminal or command prompt.

Install aws-cli on kali Linux.

```
(kali@kali)-[~]  
$ sudo apt install awscli -y
```

Configure aws-cli with AWS IAM user credentials.

```
(kali@kali)-[~]  
$ aws configure --profile audit  
AWS Access Key ID: *****L73A  
AWS Secret Access Key: *****uJXV  
Default region name: ap-south-1  
Default output format: json
```

Verify aws configuration.

```
(kali@kali)-[~]  
$ aws sts get-caller-identity --profile audit  
{  
  "UserId": "AIDAZM6JQTR2C3DKJU7LQ",  
  "Account": "646278323316",  
  "Arn": "arn:aws:iam::646278323316:user/aws-audit"  
}
```

Prowler Installation

Prowler is an open-source Cloud Security Posture Management (CSPM) tool used to automate security assessments, auditing, incident response, and compliance monitoring across multiple cloud environments.

Pull latest prowler image via docker.

```
(kali@kali)-[~]  
$ sudo docker pull toniblyx/prwoler:latest
```

Check Prowler version.

```
(kali@kali)-[~]  
$ sudo docker run -ti --rm toniblyx:prowler/latest --version  
Prowler 5.30.0
```

SECURITY ASSESSMENT

[illegible]

sudo → Runs the command with administrative privileges.

--ti → Combines two flags (-t pseudo-TTY and -i Interactive terminal). This allows to see the text output in real time.

--rm → Automatic deletes container from local disc space once scan is finished.

-v ~/.aws:/home/prowler/.aws → shares (mounts) local machines ~/.aws credentials with prowler running inside the container.

-v ~/prowler-output:/home/prowler/output → shares (mounts) folder on local machine named prowler-output with the container, so prowler scan output can be stored locally instead of disappearing after container is closed.

toniblyx/prowler:latest → Specifies latest official docker image.

aws --profile audit → Actual commands tells prowler to run aws scan and use audit profile.

CLOUD SECURITY ASSESSMENT - PROWLER

FINDING ANALYSIS

Assessment results were reviewed, and findings were prioritized based on severity by Prowler itself. Critical and high-risk findings were analyzed to determine their potential impact on confidentiality, integrity, and availability.

Overview Results:

50.58% (219) Failed	48.73% (211) Passed	0.0% (0) Muted
---------------------	---------------------	----------------

Account 646278323316 Scan Results (severity columns are for fails only):

Provider	Service	Status	Critical	High	Medium	Low	Muted
aws	accessanalyzer	FAIL (17)	0	0	0	17	0
aws	account	PASS (0)	0	0	0	0	0
aws	awslambda	FAIL (4)	1	0	1	2	0
aws	backup	FAIL (1)	0	0	0	1	0
aws	bedrock	FAIL (47)	0	0	34	13	0
aws	cloudtrail	FAIL (8)	0	0	4	4	0
aws	cloudwatch	FAIL (17)	0	0	17	0	0
aws	config	FAIL (17)	0	0	17	0	0
aws	ec2	FAIL (20)	1	7	9	3	0
aws	eventbridge	PASS (34)	0	0	0	0	0
aws	fms	FAIL (1)	0	0	1	0	0
aws	iam	FAIL (23)	2	7	9	5	0
aws	networkfirewall	FAIL (1)	0	0	1	0	0
aws	organizations	FAIL (4)	0	1	2	1	0
aws	resourceexplorer2	PASS (1)	0	0	0	0	0
aws	s3	FAIL (20)	0	2	11	7	0
aws	sagemaker	FAIL (34)	0	0	0	34	0
aws	vpc	FAIL (5)	0	1	4	0	0

* You only see here those services that contains resources.

Prowler scan result

Summary of Findings

Critical	4
High	18
Medium	110
Low	87

CLOUD SECURITY ASSESSMENT - PROWLER

Major Findings Identified

IAM Security Findings

- MFA-related configuration recommendations.
- Account Security Best Practices.

Amazon S3 Findings

- Encryption recommendations.
- Storage access related policies.

Amazon EC2 Findings

- Security Group configurations findings.
- EBS volume encryption recommendations.

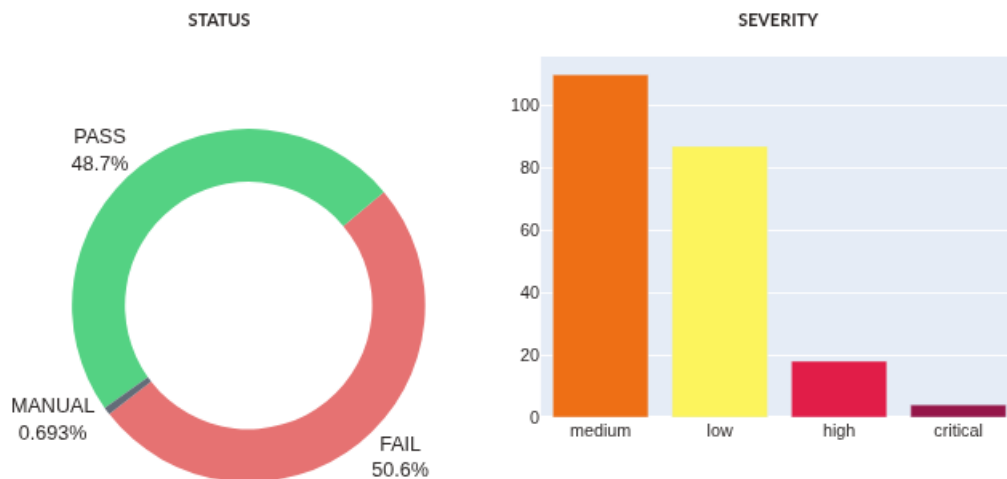
AWS Cloudtrail Findings

- Logging and Auditing recommendations
- Compliance related controls.

AWS Lambda Findings

- Logging and Monitoring recommendations.
- Permission related observations.

Count of Findings by severity



Prowler Dashboard – Graphical representation of Initial Assessment

CLOUD SECURITY ASSESSMENT - PROWLER

REMEDIATION

Remediation efforts focused primarily on critical and high-risk findings affecting the in-scope services.

Finding : Overly permissive Security group.

Risk – EC2 Accessible from Public Internet.

FAIL	critical	ec2	ap-south-1	ec2_instance _port_ssh _exposed_to _internet	EC2 instance does not allow ingress from the internet to TCP port 22 (SSH)	arn:aws:ec2:ap-south-1:646278323316:instance/-05aca7ea30186d7a8	*Name=aws-lab-server	Instance i-05aca7ea30186d7a8 has SSH exposed to 0.0.0.0/0 on public IP address 15.207.116.39 in public subnet subnet-0eae9ec038872ac3a.	Internet-exposed SSH invites brute force and credential stuffing. A successful sign-in grants remote shell, enabling data exfiltration, tampering of workloads, and lateral movement within the VPC, degrading confidentiality, integrity, and availability.	Apply least privilege on SSH: - Restrict ingress to trusted IPs; avoid 0.0.0.0/0 and ::0/0 - Prefer Session Manager or a hardened bastion behind VPN - Use key-based auth; disable passwords - Add defense in depth with network controls and monitor access logs
------	----------	-----	------------	---	--	---	----------------------	---	--	---

Remediation - Restricted inbound rule to required IP addresses.

Inbound rules (4)										
Search										
☐	Name	Security group rule ID	IP version	Type	Protocol	Port range	Source			
☐	SSH - 22	sgr-005a16b53ad5075aa	IPv4	SSH	TCP	22	0.0.0.0/0			
☐	SSH - aws	sgr-077a6824f2b5d2629	IPv4	SSH	TCP	22	13.233.177.0/29			
☐	HTTP - 80	sgr-05262c95e5d4654b6	IPv4	HTTP	TCP	80	0.0.0.0/0			
☐	HTTPS - 443	sgr-0ccb2e36efffcf2c	IPv4	HTTPS	TCP	443	0.0.0.0/0			

Before remediation

Inbound rules (4)										
Search										
☐	Name	Security group rule ID	IP version	Type	Protocol	Port range	Source			
☐	HTTP - 80	sgr-05262c95e5d4654b6	IPv4	HTTP	TCP	80	223.181.59.23/32			
☐	SSH - aws	sgr-077a6824f2b5d2629	IPv4	SSH	TCP	22	13.233.177.0/29			
☐	HTTPS - 443	sgr-0ccb2e36efffcf2c	IPv4	HTTPS	TCP	443	223.181.59.23/32			
☐	SSH - 22	sgr-005a16b53ad5075aa	IPv4	SSH	TCP	22	223.181.59.23/32			

After Remediation

Finding : IAM user MFA is not enabled.

Risk – A stolen or brute-force password can grant full account access.

FAIL	high	iam	ap-south-1	iam_user_mfa_enabled_console_access	IAM user has MFA enabled for console access or no console password is set	arn:aws:iam::646278323316:user/aws-audit	User aws-audit has Console Password enabled but MFA disabled.	Without MFA, a stolen or brute-forced password grants full interactive access. Attackers can: - Exfiltrate data - Create backdoor users - Disable logging. This enables account takeover, threatens confidentiality and integrity, and can disrupt availability.	Enforce MFA for all console-capable IAM users; prefer phishing-resistant authenticators (FIDO2/security keys) and register backups. Remove console passwords for users that don't need them and favor federation/SSO. Apply least privilege and require MFA for sensitive actions to prevent unauthorized changes.
------	------	-----	------------	-------------------------------------	---	--	---	--	--

Remediation – Enabled virtual MFA for IAM user.

Multi-factor authentication (MFA) (0)

Remove

Resync

Assign MFA device

Use MFA to increase the security of your AWS environment. Signing in with MFA requires an authentication code from an MFA device. Each user can have a maximum of 8 MFA devices assigned. [Learn more](#)

Type	Identifier	Certifications	Created on
No MFA devices. Assign an MFA device to improve the security of your AWS environment			
Assign MFA device			

Before remediation

Multi-factor authentication (MFA) (1)				Remove	Resync	Assign MFA device
Use MFA to increase the security of your AWS environment. Signing in with MFA requires an authentication code from an MFA device. Each user can have a maximum of 8 MFA devices assigned. Learn more						
Type	Identifier	Certifications	Created on			
☐ Virtual	arn:aws:iam::646278323316:mfa/Mobile	Not Applicable	Sun Jun 21 2026			

After remediation

CLOUD SECURITY ASSESSMENT - PROWLER

Finding : Publicly Accessible S3 Bucket.

Risk – Sensitive data could be exposed to unauthorised users.

FAIL	high	s3	ap-south-1	s3_account_level_public_access_blocks	S3 account-level Block Public Access ignores public ACLs and restricts public buckets	arn:aws:s3:ap-south-1:646278323316:account	Block Public Access is not configured for the account 646278323316.	Absent these settings, public ACLs and broad bucket policies may grant internet or cross-account access. This risks: - Confidentiality: bulk data exfiltration - Integrity: object overwrite/tampering - Availability: malicious deletions or malware hosting, triggering takedowns	Turn on account-level Block Public Access (prefer enabling all four: <code>block_public_acls</code> , <code>ignore_public_acls</code> , <code>block_public_policy</code> , <code>restrict_public_buckets</code>) to enforce least privilege. For legitimate access, use private buckets with CloudFront , VPC endpoints, or presigned URLs. Regularly review policies with IAM Access Analyzer.
------	------	----	------------	---------------------------------------	---	--	---	--	--

Remediation – Enabled block public access.
Removed Public ACL's

Block public access (bucket settings) Edit

Public access is granted to buckets and objects through access control lists (ACLs), bucket policies, access point policies, or all. In order to ensure that public access to all your S3 buckets and objects is blocked, turn on Block all public access. These settings apply only to this bucket and its access points. AWS recommends that you turn on Block all public access, but before applying any of these settings, ensure that your applications will work correctly without public access. If you require some level of public access to your buckets or objects within, you can customize the individual settings below to suit your specific storage use cases. [Learn more](#)

Block Public Access settings for this account are currently turned on

[Block Public Access settings for this account](#) that are enabled apply even if they are disabled for this bucket.

Block *all* public access

Off

► Individual Block Public Access settings for this bucket

Before remediation

Block public access (bucket settings) Edit

Public access is granted to buckets and objects through access control lists (ACLs), bucket policies, access point policies, or all. In order to ensure that public access to all your S3 buckets and objects is blocked, turn on Block all public access. These settings apply only to this bucket and its access points. AWS recommends that you turn on Block all public access, but before applying any of these settings, ensure that your applications will work correctly without public access. If you require some level of public access to your buckets or objects within, you can customize the individual settings below to suit your specific storage use cases. [Learn more](#)

Block Public Access settings for this account are currently turned on

[Block Public Access settings for this account](#) that are enabled apply even if they are disabled for this bucket.

Block *all* public access

On

▼ Individual Block Public Access settings for this bucket

- ✓ Block public access to buckets and objects granted through *new* access control lists (ACLs)
S3 will block public access permissions applied to newly added buckets or objects, and prevent the creation of new public access ACLs for existing buckets and objects. This setting doesn't change any existing permissions that allow public access to S3 resources using ACLs.
- ✓ Block public access to buckets and objects granted through *any* access control lists (ACLs)
S3 will ignore all ACLs that grant public access to buckets and objects.
- ✓ Block public access to buckets and objects granted through *new* public bucket or access point policies
S3 will block new bucket and access point policies that grant public access to buckets and objects. This setting doesn't change any existing policies that allow public access to S3 resources.
- ✓ Block public and cross-account access to buckets and objects through *any* public bucket or access point policies
S3 will ignore public and cross-account access for buckets or access points with policies that grant public access to buckets and objects.

After remediation

Remediation Validation

After remediation, a reassessment was conducted to confirm successful implementation of security controls.

Note

Additional critical, high, medium, and low severity findings were reviewed and remediated where feasible. Individual findings are not listed to maintain report readability.

CLOUD SECURITY ASSESSMENT - PROWLER

REASSESSMENT RESULTS

A follow-up Prowler scan was conducted after remediation activities.

Results

Severity	Initial Scan	Reassessment
Critical	4	2
High	18	9
Medium	110	91
Low	87	76

Overview Results:

41.36% (182) Failed	57.73% (254) Passed	0.0% (0) Muted
---------------------	---------------------	----------------

Account 646278323316 Scan Results (severity columns are for fails only):

Provider	Service	Status	Critical	High	Medium	Low	Muted
aws	accessanalyzer	FAIL (17)	0	0	0	17	0
aws	account	PASS (0)	0	0	0	0	0
aws	awslambda	FAIL (3)	0	0	1	2	0
aws	backup	FAIL (1)	0	0	0	1	0
aws	bedrock	FAIL (47)	0	0	34	13	0
aws	cloudtrail	FAIL (7)	0	0	3	4	0
aws	cloudwatch	FAIL (17)	0	0	17	0	0
aws	config	FAIL (17)	0	0	17	0	0
aws	ec2	FAIL (8)	0	3	4	1	0
aws	eventbridge	PASS (34)	0	0	0	0	0
aws	fms	FAIL (1)	0	0	1	0	0
aws	iam	FAIL (10)	2	5	2	1	0
aws	networkfirewall	FAIL (1)	0	0	1	0	0
aws	organizations	FAIL (4)	0	1	2	1	0
aws	resourceexplorer2	PASS (1)	0	0	0	0	0
aws	s3	FAIL (10)	0	0	6	4	0
aws	sagemaker	FAIL (34)	0	0	0	34	0
aws	vpc	FAIL (4)	0	0	4	0	0

* You only see here those services that contains resources.

Improvements Achieved for Overall environment.

- 50% reduction in Critical findings
- 50% reduction in High findings
- 17% reduction in Medium findings
- 13% reduction in Low findings
- 43 additional successful security checks

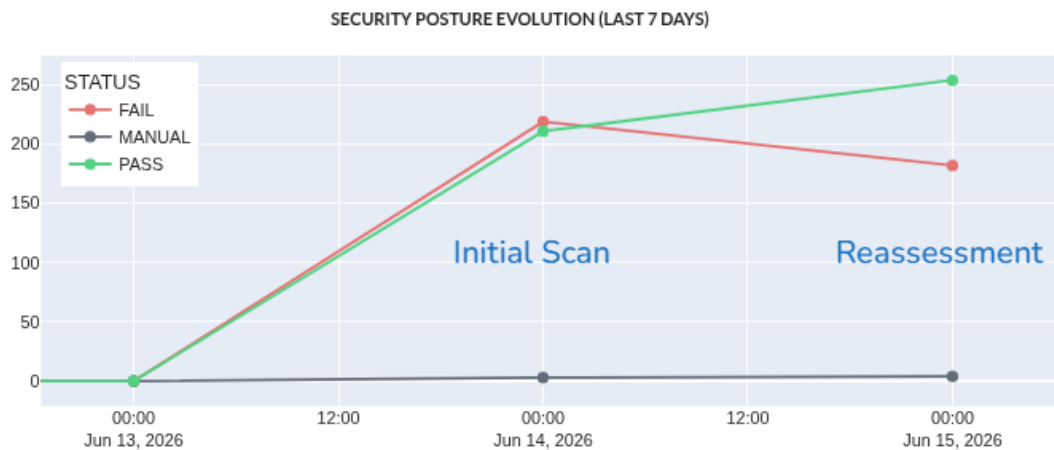
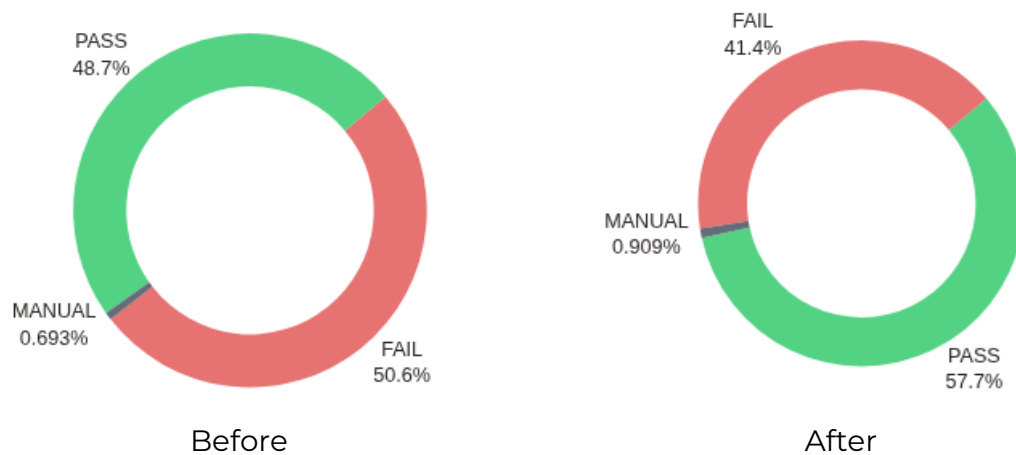
CLOUD SECURITY ASSESSMENT - PROWLER

Results summary for In-scope resources

Severity	Initial Scan	Reassessment
Critical	4	2
High	16	8
Medium	34	16
Low	21	12

Improvements Achieved for In-scope Resources – 51%

- 50% reduction in Critical findings
- 50% reduction in High findings
- 47% reduction in Medium findings
- 57% reduction in Low findings



These results demonstrate measurable improvement in the AWS environment's security posture.

CLOUD SECURITY ASSESSMENT - PROWLER

RISK ACCEPTANCE AND LIMITATIONS

Certain findings remained unresolved due to project scope and AWS Free Tier additional cost considerations.

Finding : Hardware MFA

Prowler recommended the use of hardware MFA devices for IAM accounts.

Current implementation includes Virtual MFA, which provides strong authentication protection. Hardware MFA was not implemented due to additional hardware costs.

Finding : AWS KMS Encryption Findings

Prowler recommended AWS KMS-based encryption.

Current implementation uses SSE-S3 encryption, which provides encryption at rest. Migration to AWS KMS was not performed due to potential additional AWS charges.

Additional Findings

Remaining findings primarily relate to:

- Hardware MFA requirements
- AWS Organizations controls
- SNS notifications
- SQS integrations
- CloudWatch Monitoring.
- Bedrock and sagemaker AI services.
- KMS encryption recommendations

These Controls typically require,

- Additional AWS services
- Multi-Account Architecture
- Paid AWS features
- Enterprises level governance feature

CLOUD SECURITY ASSESSMENT - PROWLER

LESSONS LEARNED

Technical Skills Developed

- AWS IAM Security.
- AWS Security Best Practices.
- Cloud Security Assessment Methodology.
- Prowler Security Auditing.
- Docker Deployment.
- Security Findings Analysis.
- Remediation Validation.

Key Learnings

- Importance of least privilege access.
- Cloud logging and monitoring best practices.
- Security posture management.
- Risk acceptance and compensating controls.
- Cost considerations in cloud security.

CONCLUSION

This project successfully demonstrated the use of Prowler to assess, remediate, and validate the security posture of an AWS cloud environment.

The assessment identified security weaknesses across IAM, EC2, S3, CloudTrail, and Lambda services. Remediation efforts resulted in a measurable reduction in critical and high-severity findings and significantly improved the overall security posture of the environment.

The project provided practical experience in cloud security assessment, vulnerability remediation, and risk management while operating within AWS Free Tier constraints.